

W12D4

Analisi delle vulnerabilità e azioni di rimedio
Emma Rullo

Sommario

Questo documento descrive un'attività di gestione delle vulnerabilità su un sistema Metasploitable. Il lavoro è organizzato nelle tre fasi previste: una scansione iniziale con Nessus Essentials estesa a tutte le 65.535 porte TCP, con relativa analisi tecnica dei risultati; l'applicazione di interventi correttivi reali sulla macchina; una scansione finale di verifica per dimostrare la chiusura delle falle.

Sono state selezionate e corrette cinque vulnerabilità: quattro tramite riconfigurazione dei servizi (NFS, VNC, backdoor Bind Shell e r-services) e una tramite regola firewall (Telnet in chiaro). La scansione finale conferma la risoluzione di tutte e cinque: il totale delle voci rilevate scende da 69 a 62.

Ambiente di laboratorio

L'attività si è svolta in un laboratorio in UTM con una macchina attaccante e una macchina bersaglio sulla stessa rete privata.

Componente	Dettaglio
Attaccante / scanner	Kali Linux (UTM) con Nessus Essentials
Bersaglio	Metasploitable — 192.168.50.101
Sistema operativo target	Linux kernel 2.6 su Ubuntu 8.04 “Hardy” (end-of-life)
MAC address	96:81:9E:81:D6:03
Range porte	1–65535 (scansione completa, non solo porte comuni)

Parte 1 — Scansione iniziale

1 · Panoramica dei risultati

La scansione completa ha rilevato 69 vulnerabilità.

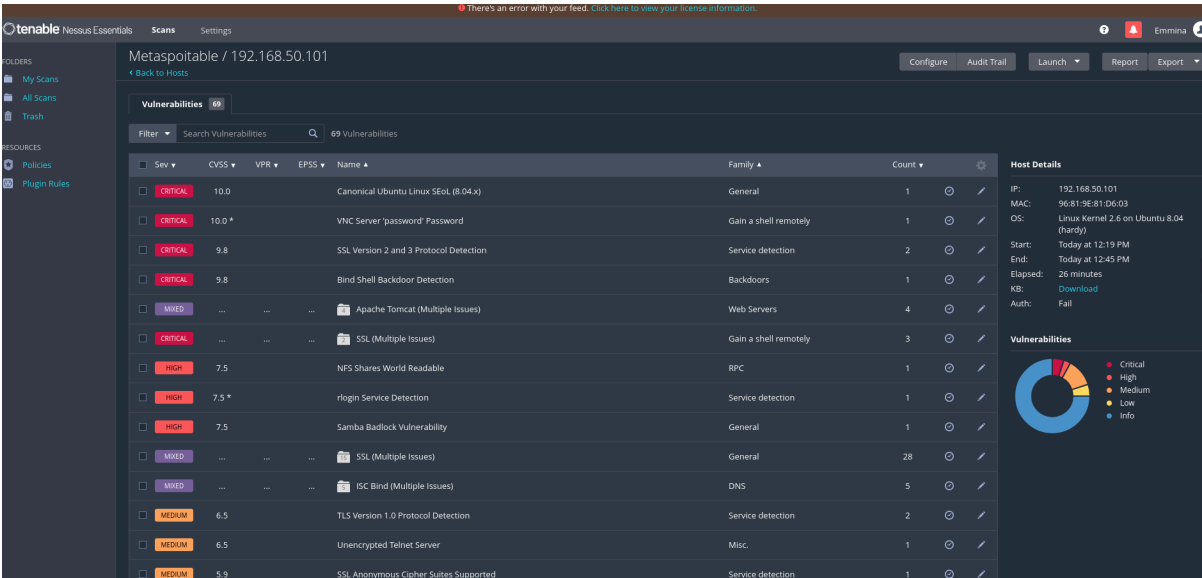


Figura 1 — Scansione iniziale: 69 vulnerabilità rilevate (Metasploitable, 192.168.50.101).

Distribuzione delle vulnerabilità per gravità

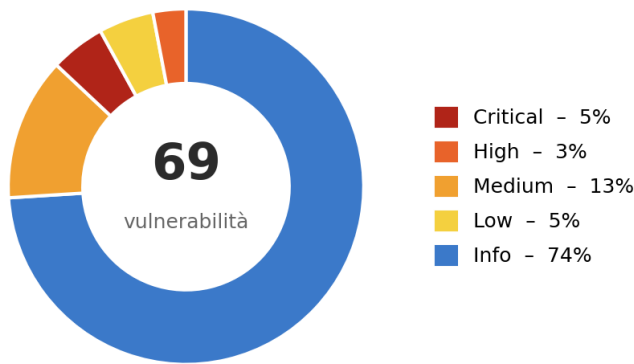


Figura 2 — Distribuzione delle 69 vulnerabilità per livello di gravità.

Le cinque vulnerabilità selezionate per la remediation sono riepilogate di seguito; l’analisi è al punto 2.

Vulnerabilità	Porta	Gravità	Punteggio
VNC Server 'password' Password	5900	Critical	CVSS 10.0
Bind Shell Backdoor Detection	1524	Critical	CVSS 9.8

Vulnerabilità	Porta	Gravità	Punteggio
NFS Shares World Readable	2049	High	CVSS 7.5
rexec / rlogin / rsh (r-services)	512–514	High	CVSS 7.5
Unencrypted Telnet Server	23	Medium	CVSS 6.5

2 · Analisi delle vulnerabilità selezionate

Per ciascuna delle cinque vulnerabilità corrette si riporta la descrizione tecnica, il servizio interessato e il modo in cui un attaccante la sfrutterebbe. La relativa remediation è nella Parte 2.

▪ VNC Server 'password' Password [CRITICAL – CVSS 10.0 (CVSS v2)]

Porta/servizio: 5900/tcp — VNC

Descrizione. Il server VNC sull'host remoto è protetto da una password debole. Nessus è riuscito ad autenticarsi tramite VNC usando la password “password”. Un attaccante remoto non autenticato può sfruttarlo per prendere il controllo del sistema. (Output Nessus: “Nessus logged in using a password of password”.)

Remediation. Proteggere il servizio VNC con una password robusta. Se l'accesso grafico remoto non serve, disabilitare il servizio.

Come si sfrutta. Un attaccante si collega con un client VNC — ad esempio vncviewer 192.168.50.101:5900 — e inserisce la password “password”; in Metasploit il modulo auxiliary/scanner/vnc/vnc_login individua la credenziale.

Risultato per l'attaccante. Sessione grafica remota completa, come se l'attaccante fosse davanti allo schermo.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0506>

▪ Bind Shell Backdoor Detection [CRITICAL – CVSS 9.8]

Porta/servizio: 1524/tcp

Descrizione. Una shell è in ascolto sulla porta remota senza richiedere alcuna autenticazione: un attaccante può usarla connettendosi alla porta e inviando comandi direttamente. Nessus ha dimostrato lo sfruttamento eseguendo il comando “id” e ottenendo privilegi di root (uid=0(root)). È una backdoor.

Come si sfrutta. La backdoor non richiede autenticazione: basta collegarsi alla porta con netcat (nc 192.168.50.101 1524) per ottenere subito una shell.

Risultato per l'attaccante. Shell di root immediata (uid=0), controllo totale del sistema

Remediation. Verificare se l'host è stato compromesso e reinstallare il sistema. Chiudere la porta non basta se il sistema è già compromesso.

Riferimento: Plugin 51988 — backdoor intenzionale di Metasploitable (nessuna CVE formale).

▪ **NFS Shares World Readable [HIGH – CVSS 7.5]**

Porta/servizio: 2049/tcp — NFS

Descrizione. Il servizio NFS esporta condivisioni di rete leggibili da chiunque (“world readable”), senza restrizioni sugli host autorizzati. Un attaccante sulla rete può montare le condivisioni e leggere i file esposti.

Come si sfrutta. Con showmount -e 192.168.50.101 si elencano gli export; se la radice è esportata in scrittura, l'attaccante monta la condivisione (mount -t nfs) e scrive la propria chiave pubblica in /root/.ssh/authorized_keys, poi entra via SSH. È il classico percorso NFS → root di Metasploitable.

Risultato per l'attaccante. Lettura di file sensibili e se l'export è scrivibile accesso come root.

Remediation. Restringere gli export in /etc/exports ai soli host autorizzati.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0554>

▪ **rexec / rlogin / rsh (r-services) [HIGH – CVSS 7.5]**

Porta/servizio: 512 / 513 / 514 tcp

Descrizione. Sono attivi i servizi di accesso remoto “legacy” (exec, login, shell). Trasmettono le credenziali in chiaro e si basano su un meccanismo di fiducia (file .rhosts) facilmente aggirabile.

Come verrebbe sfruttata. Se l'host accorda fiducia tramite .rhosts permissivi, rlogin -l root 192.168.50.101 consente l'accesso senza password; in ogni caso le credenziali viaggiano in chiaro e sono intercettabili con uno sniffer sulla rete.

Remediation. Disabilitare i servizi r-* (rlogin, rsh, rexec) e sostituirli con SSH, che offre autenticazione robusta e cifratura del canale.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0651>

▪ **Unencrypted Telnet Server [MEDIUM – CVSS 6.5]**

Porta/servizio: 23/tcp – Telnet

Descrizione. Il servizio Telnet trasmette l'intera sessione, credenziali comprese, in chiaro sulla rete. Chiunque intercetti il traffico può leggere username e password e prendere il controllo dell'accesso.

Come si sfrutta. Intercettando il traffico con uno sniffer (es. Wireshark) durante un login Telnet si leggono username e password in chiaro.

Risultato per l'attaccante. Furto delle credenziali e accesso al sistema.

Remediation. Disabilitare Telnet e utilizzare SSH per l'amministrazione remota.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0619>

Parte 2 — Remediation

Il grafico riepiloga le cinque vulnerabilità corrette, ordinate per punteggio CVSS. Per ciascuna si riportano i comandi usati, con la spiegazione di ogni singolo comando, e l'evidenza del risultato.

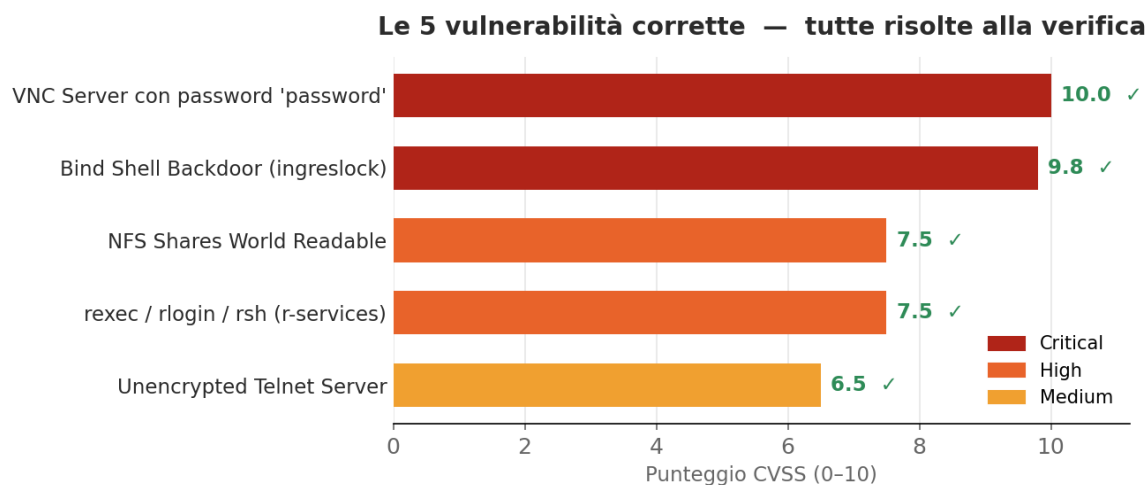


Figura 3 — Le cinque vulnerabilità corrette, per gravità.

1 · NFS Shares World Readable — porta 2049

Obiettivo: smettere di esportare il filesystem, eliminando l'accesso NFS non autorizzato.

```
cp /etc/exports /etc/exports.bak
```

crea una copia di backup del file prima di modificarlo

```
echo "# nessuna condivisione esportata" > /etc/exports
```

svuota il file sovrascrivendolo con una riga di comment e la riga che esportava a chiunque quindi sparisce:

```
/ *(rw,sync,no_root_squash,no_subtree_check)
```

/ = la condivisione esportata è la **radice**, cioè l'intero filesystem.

***** = l'asterisco significa **qualsiasi host**: nessuna restrizione su chi può montarla.

rw = accesso in **lettura e scrittura**.

sync = scritture sincrone su disco (solo una modalità di scrittura, non c'entra con la sicurezza).

no_root_squash = il root del client resta **root anche sui file esportati**

(normalmente verrebbe "declassato" a utente anonimo). Combinato con **rw**, consente di scrivere ovunque come root, da qui il percorso NFS → scrivo in **/root/.ssh/authorized_keys** → entro via SSH.

no_subtree_check = disabilita un controllo interno di NFS, influente sul rischio.

```
exportfs -ra
```

ricarica la tabella NFS secondo il file, ora vuoto, quindi nessun export resta attivo

```
/etc/init.d/nfs-kernel-server restart
```

riavvia il servizio NFS, per sicurezza, così non resta nulla in memoria.

```
showmount -e localhost
```

elenca le condivisioni esportate e deve ora risultare vuoto.

```
root@metasploitable:~# cp /etc/exports /etc/exports.bak
root@metasploitable:~# echo "# nessuna condivisione esportata (remediation W1204)" > /etc/exports
root@metasploitable:~# exportfs -ra
root@metasploitable:~# /etc/init.d/nfs-kernel-server restart
* Stopping NFS kernel daemon
... done.
* Unexporting directories for NFS kernel daemon...
... done.
* Exporting directories for NFS kernel daemon...
... done.
* Starting NFS kernel daemon
... done.
root@metasploitable:~# showmount -e localhost
Export list for localhost:
root@metasploitable:~#
```

Figura 4 — Rimozione dell'esportazione NFS: showmount non elenca più alcuna condivisione.

2 · VNC Server con password “password” — porta 5900

Obiettivo: sostituire la password banale con una robusta, mantenendo il servizio funzionante.

```
vncserver -kill :0
```

spegne il server VNC in esecuzione, siccome la password è caricata in memoria, va fermato per cambiarla.

```
vncpasswd
```

imposta una nuova password robusta

```
vncserver :0 -geometry 1024x768 -depth 24
```

riavvia il VNC sullo stesso display :0 (porta 5900) con la nuova password; i parametri sono risoluzione e profondità colore.

```
netstat -tlnp | grep 5900
```

verifica che la porta 5900 sia di nuovo in ascolto

```
root@metasploitable:~# vncserver -kill :0
Killing Xtightvnc process ID 4785
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:~# vncserver :0 -geometry 1024x768 -depth 24

New 'X' desktop is metasploitable:0

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/metasploitable:0.log

root@metasploitable:~# netstat -tlnp | grep 5900
tcp        0      0 0.0.0.0:5900          0.0.0.0:*             LISTEN      6722/Xtightvnc
root@metasploitable:~#
```

Figura 5 — Reimpostazione della password VNC e riavvio del servizio sulla porta 5900.

3 · Bind Shell Backdoor — porta 1524

Obiettivo: eliminare la shell di root accessibile senza password sulla porta 1524.

Per documentare la gravità, la backdoor è stata sfruttata dalla Kali con netcat prima dell'intervento:

```
nc 192.168.50.101 1524
```

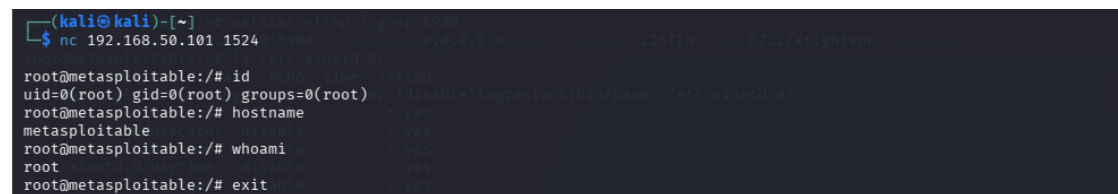
si collega alla porta 1524: la backdoor fornisce immediatamente una shell, senza chiedere password.

```
id
```

mostra l'identità dell'utente della shell ottenuta: uid=0(root).

```
whoami
```

conferma: root.



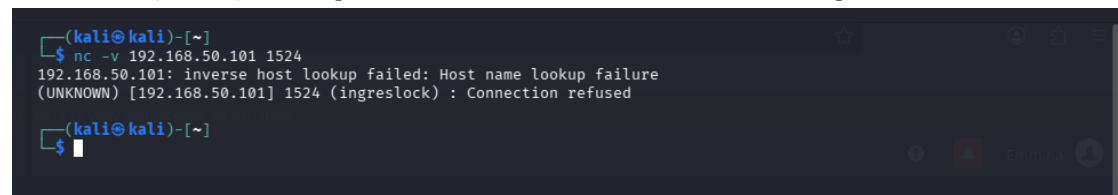
```
(kali@kali)-[~]
$ nc 192.168.50.101 1524
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# hostname
metasploitable
root@metasploitable:/# whoami
root
root@metasploitable:/# exit
```

Figura 6 — PRIMA: accesso come root tramite la backdoor, senza password (netcat sulla porta 1524).

L'intervento che chiude la backdoor è condiviso con il punto 4 (stessa configurazione), riportato lì. Dopo l'intervento, lo stesso tentativo da Kali viene respinto:

```
nc -v 192.168.50.101 1524
```

-v (verbose) rende esplicito l'esito del tentativo di connessione: ora risponde Connection refused.



```
(kali@kali)-[~]
$ nc -v 192.168.50.101 1524
192.168.50.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection refused
(kali@kali)-[~]
$
```

Figura 7 — DOPO: la connessione alla porta 1524 è rifiutata. Backdoor eliminata.

4 · r-services (rexec/rlogin/rsh) e backdoor — porte 512/513/514/1524

Obiettivo: disattivare i servizi legacy e la backdoor, tutti definiti in /etc/inetd.conf.

```
cp /etc/inetd.conf /etc/inetd.conf.bak
```

crea un backup del file di configurazione prima di modificarlo.

```
sed -i 's/^shell/#shell/; s/^login/#login/; s/^exec/#exec/; s/^ingreslock/
#ingreslock/' /etc/inetd.conf
```

mette un # all'inizio delle quattro righe, disattivandole: shell (rsh/514), login (rlogin/513), exec (rexec/512) e ingreslock (la backdoor/1524).

```
/etc/init.d/xinetd restart
```

riavvia xinetd, che rilegge /etc/inetd.conf (modalità -inetd_compat, vedi punto 6) e non apre più quei servizi.

```
netstat -tlnp | grep -E '512|513|514|1524'
```

verifica: non deve restituire alcuna riga. Le quattro porte sono chiuse.

```
root@metasploitable:~# cp /etc/inetd.conf /etc/inetd.conf.bak
root@metasploitable:~#
root@metasploitable:~# sed -i 's/^shell/#shell/; s/^login/#login/; s/^exec/#exec/; s/^ingreslock/#ingreslock/' /etc/
root@metasploitable:~# /etc/init.d/xinetd restart
 * Stopping internet superserver xinetd: [ OK ]
 * Starting internet superserver xinetd: [ OK ]
root@metasploitable:~# netstat -tlnp | grep -E '512|513|514|1524'
root@metasploitable:~# iptables -A INPUT -p tcp --dport 23 -j DROP
root@metasploitable:~# iptables -L INPUT -n --line-numbers | grep -E 'Chain|23'
```

Figura 8 — Disattivazione dei servizi e verifica: nessuna delle porte 512/513/514/1524 è più in ascolto.

5 · Unencrypted Telnet Server — porta 23 (intervento via firewall)

Obiettivo: mitigare il Telnet in chiaro bloccando la porta 23. È l'unica vulnerabilità che è stata gestita via firewall.

```
iptables -A INPUT -p tcp --dport 23 -j DROP
```

aggiunge (-A) alla catena INPUT una regola che scarta (DROP) ogni pacchetto TCP in ingresso diretto alla porta 23 (--dport 23)

```
iptables -L INPUT -n --line-numbers | grep -E 'Chain|23'
```

elenca le regole della catena INPUT e conferma la presenza della regola DROP su dpt:23.

```
root@metasploitable:~# netstat -tlnp | grep -E '512|513|514|1524'
root@metasploitable:~# iptables -A INPUT -p tcp --dport 23 -j DROP
root@metasploitable:~# iptables -L INPUT -n --line-numbers | grep -E 'Chain|23'
Chain INPUT (policy ACCEPT)
1 DROP tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:23
root@metasploitable:~#
```

Figura 9 — Regola firewall attiva: DROP sul traffico in ingresso verso la porta 23.

Nota

Le voci di `rexec`, `rlogin`, `rsh` e della `backdoor` risiedono in `/etc/inetd.conf`, il file del classico super-server `inetd`. Tuttavia il comando `netstat` mostrava che le porte 512/513/514/1524 erano gestite da `xinetd`, non da `inetd` e il vecchio `inetd` non risultava nemmeno in esecuzione. Analizzando i processi (`ps aux`) si è trovata la spiegazione: `xinetd` era avviato con il flag `-inetd_compat`, che gli fa leggere anche il file `/etc/inetd.conf`, oltre alla propria cartella `/etc/xinetd.d/`.

```
# Simple configuration file for xinetd
#
# Some defaults, and include /etc/xinetd.d/
defaults
{
    # Please note that you need a log_type line to be able to use log_on_success
    # and log_on_failure. The default is the following :
    # log_type = SYSLOG daemon info
}

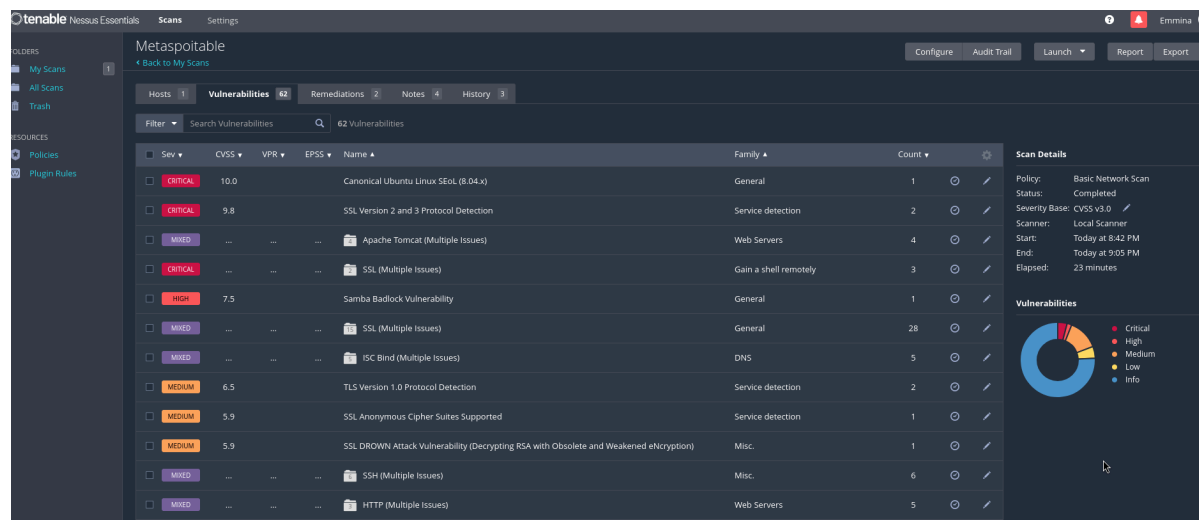
includedir /etc/xinetd.d
root@metasploitable:~# ps aux | grep inetd | grep -v grep
root  4628  0.0  0.1  2424  868 ?        Ss   06:06   0:00 /usr/sbin/xinetd -pidfile /var/run/xinetd.pid -stayalive -inetd_compat
root@metasploitable:~#
```

Figura 10 — Il flag `-inetd_compat` nella riga di comando di `xinetd`: la chiave del comportamento osservato.

Quindi era corretto modificare `/etc/inetd.conf` (il posto), ma andava riavviato `xinetd` e non `inetd` (come farlo). Senza l'ispezione preventiva, l'intervento sarebbe sembrato applicato ma le porte sarebbero rimaste aperte.

Parte 3 — Scansione finale (ScansioneFine)

Al termine degli interventi è stata rilanciata la stessa scansione completa (1–65535). Il totale delle voci rilevate scende da 69 a 62 e le cinque vulnerabilità corrette non compaiono più nell'elenco.



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
MIXED				Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL				SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5			Samba Badlock Vulnerability	General	1
MIXED				SSL (Multiple Issues)	General	28
MIXED				ISC Bind (Multiple Issues)	DNS	5
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2
MEDIUM	5.9			SSL Anonymous Cipher Suites Supported	Service detection	1
MEDIUM	5.9			SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened e(c)ryption)	Misc.	1
MIXED				SSH (Multiple Issues)	Misc.	6
MIXED				HTTP (Multiple Issues)	Web Servers	5

Figura 11 — Scansione finale: 62 vulnerabilità. Le cinque voci corrette sono scomparse.

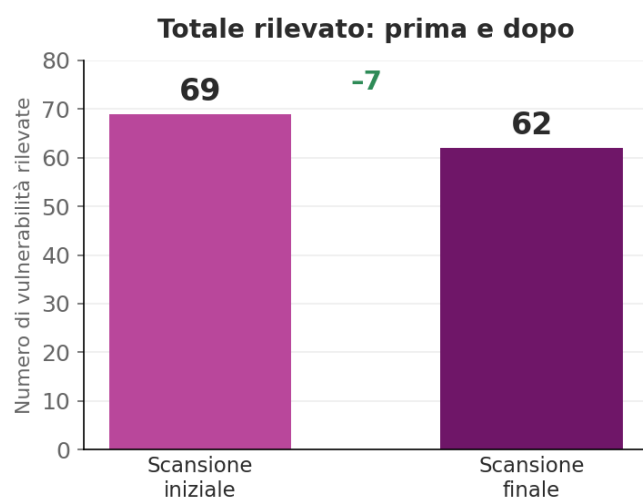


Figura 12 — Totale rilevato prima e dopo gli interventi.

Conclusioni

L'attività ha portato alla correzione verificata di cinque vulnerabilità, due delle quali critiche (CVSS 10.0 e 9.8). L'eliminazione della backdoor e del VNC a password banale ha rimosso le due vie più immediate di compromissione del sistema e la prova con netcat mostra il passaggio da "shell di root a chiunque" a "connessione rifiutata". Gli interventi, a parte una singola regola

firewall, hanno agito direttamente sulla causa, riconfigurando i servizi. La scansione finale conferma l'efficacia degli interventi perchè le cinque voci selezionate non sono più rilevabili.